

Information Security Incident Response Procedure



Standard Operating Procedure: Information Security Incident Response

Standard Operating Procedure for Information Security Incident Response

Version	4.0
Effective Date	13-10-2025
Compiled by	Saurabh Kumar
Reviewed by	Ratnesh Singh
Approved by	Chief Information Security Officer (CISO)

Revision and Version Control:

Version	Date	Reason for Revision/Update	Created/Updated By	Reviewed By	Approved By
1.0	23-01-2023	First Copy	Hiten Kumar	Nikhil Bhujade	CISO
2.0	16-01-2024	Added Escalation Matrix	Hiten Kumar	Sumit Rangari	CISO
3.0	03-07-2024	Added unusual cyber incident and RBI circular dated Jan 2024, RACI & team responsibility	Ratnesh Singh	CISO	CRO
3.1	19-05-2025	Added additional regulators in the list of regulators.	Saurabh Kumar	Ratnesh Singh	CISO
4.0	13-10-2025	1. Update RACI matrix 2. Incident reporting 3. Forensic SOP reference	Saurabh Kumar	Ratnesh Singh	CISO



Standard Operating Procedure: Information Security Incident Response

Contents

1. PURPOSE:	4
2. SCOPE:	4
3. ABBREVIATION:	4
4. RESPONSIBILITIES:	4
5. TRIAGE AND SCOPING PHASE:	5
5.1 Security incident	5
5.2 Unusual Cyber incident	6
5.3 Incident Reporting	6
5.4 Initial Incident Reporting Parameters	7
5.5 Incident Classification	7
6. PREPARATION:	7
7. EXECUTION:	8
7.1 Containment	8
7.2 Analysis	8
7.3 Forensic Analysis	8
8. POST INCIDENT REVIEW & INCIDENT DOCUMENTATION	9
9. REPORTING TO REGULATOR	9
10. RACI Matrix	10
11. ESCALATION MATRIX	11
12. REVIEW	12



Standard Operating Procedure: Information Security Incident Response

1. PURPOSE:

The purpose of this document is to provide guidelines and plan for responding to various information security and cyber incidents.

2. SCOPE:

This procedure applies to the Information Systems, Organizational data, Networks, servers and any person or device gaining access to these systems and data at PFL.

3. ABBREVIATION:

PFL	Poonawalla Fincorp Limited
CRO	Chief Risk Officer
CTO	Chief Technology Officer
CISO	Chief Information Security Officer
IT	Information Technology
SOC	Security Operation Centre
SIEM	Security Information and Event Management
IRC	Internet Relay Chat
PSD	Poonawalla Service Desk
TPSP	Third Party Service Provider
IOC	Indicator of Compromise
Event	An event is an exception to normal operations of IT infrastructure, systems, or services. Not all events become incidents
Incident	An event that violates the Information Security Policy, other policies, standards, or code of conduct or threatens the confidentiality, integrity, or availability of information systems or organizational data
CSITE	Cyber Security and Information Technology Examination
Cert-In	Indian Computer Emergency Response Team
UIDAI	Unique Identity Authority of India
I4C	Indian Cyber Crime Co-ordination Centre

4. RESPONSIBILITIES:

- The responsibility of executing this procedure lies with the Information Security Team.
- There are two ways to get security incident alert i.e. SIEM tool and PSD tool.
- Security incidents triggered through SIEM tool and PSD tool are monitored by SOC team (Vendor managed services) and by SOC team (PFL Information Security team) respectively.



Standard Operating Procedure: Information Security Incident Response

- Employees can also report suspected IT security incidents or breaches of the privacy or security of restricted data to the Information Security team via email and PSD tool.
- Based on the type and scope area, below are the team responsibility for the information security incident:

S. No.	Scope Areas	Responsibility
1	Severs	IT Infra team shall investigate the security incident in coordination with Information Security team and Network team.
2	Network devices	Network team shall investigate the security incident in coordination with Information Security team.
3	Applications	Application team shall investigate the security incident in coordination with Information Security team, network, and IT Infra team.
4	End user system	End user support team in coordination with Information Security team.
5	Physical Security	Admin team shall investigate the physical Security incident in coordination with Information Security team.

5. TRIAGE AND SCOPING PHASE:

- Security incidents are managed and tracked using SIEM and PSD tool.
- Security incidents triggered through SIEM tool are managed by SOC team (vendor managed services) and through PSD tool by SOC team (PFL team) respectively.
- This involves the process of analysing the information about the situation to determine whether a security incident has occurred.
- This includes incident identification, initial reporting, priority setting based on data, system criticality and sensitivity, required collection and analysis of incident information, information preservation, documentation, and communication.

5.1 Security incident

An occurrence that actually or potentially compromises the confidentiality, integrity, or availability of an information system or the information system processes. A security incident may involve, but is not limited to any or all the following:

- A violation of organizational policies and standards
- Unauthorized IT systems or information access
- Loss of information confidentiality
- Attack on critical infrastructure



Standard Operating Procedure: Information Security Incident Response

- Website defacement
- Loss of system or information availability (system outage/ downtime)
- Compromise of system or information integrity
- Virus and code Attack
- Unauthorized access to social media accounts
- Denial of service condition against data, network, or computer
- Misuse of service, systems or information
- Physical or logical damage to systems, or device theft
- Presence of an unauthorized application, such as malware
- Unauthorized or suspicious network activity

5.2 Unusual Cyber incident

Unusual cyber incident may involve, but is not limited to, any or all the following:

- Malware, Ransomware attack.
- Data/ customer information/ business information breach.
- Malicious traffic observed from bank's information system to a suspicious IP/ Command & Control terminal (or) any other internal/ external information system.
- Denial of Service (DoS) | Distributed Denial of Service (DDoS) attacks exceeding 30 minutes.
- Customer service disruption (Beyond a threshold time limit defined by RBI)
- Exploitation of vulnerabilities resulting into compromise of integrity of the system/ application. (e.g., Parameter manipulation/man-in-the-middle type of incidents).
- Email phishing, spoofing attacks leading to execution of fraudulent transactions.
- Website defacement.
- Any other type of cyber incident not necessarily falling into one of the above.

For step-by-step cyber incident response, please refer cyber response SOP.

For DLP incidents, refer DLP Incident response procedure SOP.

5.3 Incident Reporting

- Incident identified through SIEM tool
 - ✓ SOC team (PFL Team) will analyse the security events monitored through SIEM tool and reported through various sources to detect security incidents such as open web, threat intel, IRC, IOCs, and Dark/deep web.
 - ✓ Identified security events shall be communicated to respective stakeholders through incident notification.
- Security incident reported by employees



Standard Operating Procedure: Information Security Incident Response

- ✓ All applicable IT security incidents should be logged in PSD Tool or should be reported via email for assigning task to backend team.
- ✓ If the attack was performed or attempted on end user system, then they need to immediately inform the Information security team by raising the incident ticket in cyber information security incident categories on PSD tool or by mail.
- ✓ The initial severity level may be increased or decreased by Information Security Team based for logged incident basis due diligence and investigation (refer Annex).
- ✓ All suspected or confirmed Information Security incidents must be reported to Information Security Team, CISO and CRO.

5.4 Initial Incident Reporting Parameters

Initial incident reporting to Information Security team should include the following information when describing the incident:

- Date and time of incident discovery
- General description of the incident
- Source and destination IP
- Threat score or IP reputation check
- Systems or data at possible risk
- Actions they have taken since incident discovery (if any)
- Contact information
- Any additional relevant information known at the time

5.5 Incident Classification

Incident classification helps in identifying the priority of incident depending upon the severity & impact. It also ensures that the incident receives the appropriate level of attention and is reported to management/ stakeholders in a timely manner as per the priority.

- All the security incidents through SIEM tool shall be classified based on severity defined as per the use cases under SIEM tool.
- All the security incidents through PSD tool shall be classified by Information Security Team.

6. PREPARATION:

- The SOC team (PFL Team) shall collect and review the incident documentation and event reports. This information should first be verified as being factual (information may have been misreported or incorrectly documented).
- The SOC team (PFL Team) assigns the incident severity or re-considers its appropriateness if already assigned.
- CISO and CRO shall determine true incident in consultation with senior leadership.



Standard Operating Procedure: Information Security Incident Response

- If the incident requires forensic analysis, arrangements must be made to gain access to the data and devices involved in the incident by the Information Security team.

7. EXECUTION:

- Incident triggered through SIEM
 - ✓ Based on the analysis of log, SOC team (PFL Team) shall send out the notification to the concern team such as Information Security team, technology teams and end user support team.
 - ✓ Concerned team shall work on security incidents in coordination with different teams (if required) such as network, servers, and technology team.
 - ✓ Corrective actions for the identified incident shall be confirmed to Information Security Team.
 - ✓ Information Security Team/Infra team shall confirm to SOC team (vendor managed service) for closure of ticket after appropriate action taken.
- Incident triggered through PSD
 - ✓ SOC team (PFL team) shall be responsible for identification and investigation of incidents logged in PSD tool.
 - ✓ Information Security Team shall be responsible for notifying the identified incident to the concern team.

7.1 Containment

- Upon incident communication, concerned teams/ departments are responsible to engage sufficient staff with appropriate technical skills to do containment.
- Information Security Team, CISO along with respective business functions must assess whether the incident has affected and disrupted services to internal or external customers.
- Decisions of this nature must be made in consultation with the appropriate senior leadership (CISO, CRO, CTO) and an evaluation of whether the systems impact critical services.

7.2 Analysis

- SOC team (PFL Team) and respective team (IT, Infra, Application etc.) shall assess the cause and type of breach.
- Depending on the logs analysed by system owner team, SOC team (PFL Team) should either validate or determine what types of data are involved, based on classification of information assets. The cause of the breach is determined by technical analysis and investigation, as described in forensic analysis.

7.3 Forensic Analysis

- Forensic analysis entails a technical examination of evidence, preservation of that evidence, preservation of the chain-of-custody of the evidence, documentation of

Standard Operating Procedure: Information Security Incident Response

- observations, and analysis drawn from logical conclusions based on the evidence, absent opinion, or conjecture.
- Kindly refer to the Digital Forensic SOP for more information and procedural guidance.
 - When conducting a forensic analysis, the analyst must adhere to the following principles:
 - a. Analysis must be an unbiased examination of the evidence submitted.
 - b. Chain of custody and evidence integrity is maintained through the whole process of investigation.
 - c. Forensic analysis does not pronounce or imply guilt. The purpose is to determine whether indicators exist that can tie the suspect hardware or identity to the incident under investigation.
 - d. Report only verifiable information.
 - e. Be precise, Statements such as “numerous,” “many,” “multiple hundreds,” etc. should be avoided.
 - f. Specifically state the finding, as well as the precise locations of information.
 - g. Identify the evidence being analysed as thoroughly as possible.

8. POST INCIDENT REVIEW & INCIDENT DOCUMENTATION

- Responsible Team is liable for recovery and will communicate status & results to Information Security Team at scheduled intervals.
- Scope of review includes circumstances and activities before the incident as well as during the response.
- The Incident document shall be adequately and sufficiently detailed.
- The documentation should contain details like Incident name and description, Root cause, resolution steps taken by respective teams, learnings from the incident etc.
- Incident documentation helps prevent similar occurrences of incident in future in the organization.
- Share lessons learned with appropriate stakeholders.
- If required, an action plan may be required as per recommended changes to improve the IT environment going forward.

9. REPORTING TO REGULATORS/ AUTHORITIES

Information Security incidents shall be reported to applicable regulators / authorities such as RBI, Cert-In, UIDAI (if applicable) within prescribed time limits by the respective regulators and other authorities on case-to-case basis (if applicable) such as SEBI, Indian cybercrime co-ordination centre (I4C) and IRDAI etc.



Standard Operating Procedure: Information Security Incident Response

PFL to follow incident reporting guidelines to ensure timely reporting as per regulatory requirements.

These concerns include:

- Incident shall be reported to Regulators (e.g. RBI) in coordination with compliance & legal team in timely manner within 6 hours of detection, unless explicitly mentioned otherwise.
- PFL shall be reporting the incidents as per the recommended method of reporting [such as DAKSH portal - <https://daksh.rbi.org.in>]
- The incidents should be reported by the CISO, or any other competent authority designated for this purpose by the PFL.

**** for Cyber incident related reporting, refer Cyber incident response SOP and latest regulatory guidelines (mentioned in annexure).**

10. RACI Matrix

RACI matrix for true incidents.

Action Item	Responsible	Accountable	Consulted	Informed
Incident Reporting to Information Security Team	End Users/ MSSP SOC Team	Information Security Team	CISO	CRO
Identification and classification of Incident	PFL SOC Team	Information Security Team	CISO	CRO
Notification to Stakeholders (Internal)	PFL SOC Team	Information Security Team,	CISO	CRO, CTO
Incident Response, Containment & Recovery	Respective Team (IT, INFRA, Application)	Information Security Team	CISO, IT Governance	CRO, CTO
Analysis of Incident	PFL SOC Team & Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance,	CISO, CTO	CRO, Business HOD
Root cause Analysis of the Incident	Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance	CISO, CTO	CRO, Business HOD
Impact Assessment of the Incident	Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance	CISO, CTO	CRO, Business HOD



Standard Operating Procedure: Information Security Incident Response

Incident/ ticket Closure	MSSP SOC Team, Respective Team (IT, INFRA, Application)	Information Security Team, IT Governance	CISO, CTO	CRO
Reporting to External stakeholders / Regulators / Authorities	Regulators - Compliance Team Media - Head Corporate Communication (PR)	Information Security Team, IT Governance	CISO, CTO	CRO, Business HOD

* For incidents related to unavailability / application outages, IT team is responsible to report the same to Information security team with all required details along with HOD approval for further reporting to regulators.

** For incidents related to cyber fraud affecting individual staff, particular staff needs to directly report the same to I4C at www.cybercrime.gov.in; they can seek guidance and advice from Information security team.

*** For cyber fraud affecting the organization, the FCU/FRM/Ops team need to co-ordinate with Information security and compliance team for further reporting to I4C (www.cybercrime.gov.in).

11. ESCALATION MATRIX

- Point of contact for Information / Cyber security related incidents.

Escalation Level	Name	Infosec	Contact No	Designation
Level 1	Infosec	infosec@poonawallafincorp.com	-	Infosec Support
Level 2	Ratnesh Singh/ Sumit Rangari	ratnesh.singh@poonawallafincorp.com / sumit.rangari@poonawallafincorp.com	7032717376/ 9860257758	AVP
Level 3	Nikhil Bhujade	nikhil.bhujade@poonawallafincorp.com	8956594991	CISO

- Point of contact for IT Infrastructure related incidents

Escalation Level	Name	IT Infra	Contact No	Designation
Cloud- Level 1	Cloud Team	dc.wintel@poonawallafincorp.com	NA	NA
Cloud- Level 2	Dheeraj Kale	dheeraj.kale@poonawallafincorp.com	9920600341	GM – IT Infra
Network- Level 1	Network Team	dc.network@poonawallafincorp.com	NA	NA
Network- Level 2	Nilesh Waykar	nilesh.waykar@poonawallafincorp.com	9881335584	Network Lead
Cloud / Network Level 3	Chandresh Yadav	chandresh.yadav@poonawallafincorp.com	9920044647	VP – IT Infra
Level 4	Salil Hajarnis	salil.hajarnis@poonawallafincorp.com	9823216761	CTO

***Standard Operating Procedure: Information Security Incident Response***

12. REVIEW

This document shall be reviewed at least once annually or whenever any major changes occur in the process or regulatory requirements.

Classification | INTERNAL



Standard Operating Procedure: Information Security Incident Response

Annexure:

A. Incidents reported by end-users' priority in PSD tool may be re-categorized as per below table

Priority Level	Description	Response Time	Resolution Time
P1 Critical	- Data breach, ransomware, or major security compromise affecting all users or critical systems.	Within 1 hour	ASAP / Best Effort (typically within 8 hours)
P2 - High	Multiple users affected by the incident (> 5) or high-risk issues	Within 2 hours	Within 24 hours
P3 Medium	- Limited users affected (<5), moderate risk issues.	Within 4-24 hours	Within 48 hours
P4 - Low	Minor issues, informational alerts.	Within 48 hours	Within 96 hours

B. Cyber Incident that requires reporting to RBI/CSITE:

- Unusual Cyber Incidents (Refer Point-5.2 for Unusual Cyber Incidents)
- Instances wherein **deficiencies in the PFL or TPSP's** or in any of the entity in the payment ecosystem's (e.g., payment aggregator, payment gateway, payment system operator) internal systems/ applications/ processes (including reconciliation exercise associated with payment ecosystem) results into wrongful credit/ debit to the PFL / customers/ others amounting to **30 lakh or more**, if applicable.
- Leakage of **card data** (or) card data exposed in the public domain/ dark web only if total number of cards exceeds 1000 in one instance (or) cumulatively total number of cards exceeds 1000 in multiple instances in a week, if applicable.
- Significant levels of **customer service disruptions** due to **the non-availability of IT** systems of PFL (irrespective of whether it is managed by PFL or TPSPs) must be reported.

The reporting requirement (as applicable to NBFCs) is as follows:

- For Unplanned downtime**

- Beyond 2 hours of downtime between 8 am and 8 pm (or)
- Beyond 4 hours of continuous downtime.

- For Planned downtime**

Any planned downtime activity where the downtime window is more than 8 hours.

- Any cyber incident (or) potential cyber incident which poses a major reputational impact to PFL encompassing negative press/ unfavourable media coverage, social media attention should also be reported.
- A major near-miss cyber-attack with the potential to escalate into an unusual cyber incident.



Standard Operating Procedure: Information Security Incident Response

C. Incident Reporting Template

Sample field required for reporting the Incident to RBI:

1. Incident Title & short description of the Incident
2. Incident occurrence date & Time (DD/MM/YYYY: HH, MM)
3. Incident detection date & time (DD/MM/YYYY: HH, MM)
4. Affected System details
5. Location of Incident (PFL / TPSP etc.)
6. Whether incident reported to regulatory body (Cert-in, IBCART etc.)
7. Whether RCA available or not
8. Recovery status and details

D. RCA and Follow-up data submission to Regulators

- 1) PFL shall respond to queries raised by CSITEG on DAKSH portal within five working days whenever a clarification query is raised by RBI or additional data is requested to be submitted.
- 2) RCA report be submitted to RBI within **10 working days** from the initial detection of the incident. The RCA should contain all data fields as per the regulator's requirements.

Refer CSITE "guidelines on reporting unusual cyber incidents" for updated requirements.

E. Contact Details of Regulators / Authorities

Mandatory reporting to the following regulators / authorities:

Name of Regulator	Address	Incident Reporting Method
Reserve Bank of India	Reserve Bank of India, Department of Supervision, 3rd Floor, World Trade Centre, Cuffe Parade, Colaba, Mumbai - 400 005.	RBI's DAKSH Portal https://daksh.rbi.org.in/

Cyber incidents shall be reported to the following regulators / authorities as per the cyber incident response procedure:

Name of Regulator	Address	Incident Reporting Method
Cert-In	Indian Computer Emergency Response Team Electronics Niketan, CGO Complex, New Delhi 110003	Email: incident@cert-in.org.in Fax: +91-11-24368546
UIDAI	Unique Identification Authority of India, Bangla Sahib Road, Behind Kali Mandir, Gole Market, New Delhi - 110001	Email: help@uidai.gov.in Call: 1947 Or any acceptable method prescribed by UIDAI
CyMAC Control Room	Cyber Multi Agency Centre (CyMAC) Ministry of Home Affairs, GOI	Email: cycordadmin.mha@gov.in Landline: 011- 23094060

Incident Reporting to below regulators / authorities only if applicable:

Standard Operating Procedure: Information Security Incident Response

I4C - National Cyber Crime Reporting Portal	Indian Cybercrime Coordination Centre, 5th Floor, NDCC-II Building, Jai Singh Road, New Delhi	https://cybercrime.gov.in/ or Call: 1930
SEBI	SEBI Bhavan, Plot C4-A, G Block, Bandra Kurla Complex, Mumbai - 400051	Email: mkt_incidents@sebi.gov.in
IRDAI	Insurance Regulatory Development Authority of India (IRDAI), Sy No. 115/1, Financial District, Nanakramguda, Gachibowli, Hyderabad – 500032	Email: infosec@irdai.gov.in

Classification | INTERNAL